

MALWARE INFECTION INCIDENT RESPONSE

Detection, Containment, Eradication and Recovery Plan

Cybersecurity Incident Response Case Study

Scenario: Malware is detected on 20 computers in an organization.

Prepared for: Cybersecurity / Information Security Assignment

Date: September 2026

Executive Summary

This report explains how an organization should respond when malware is detected on 20 computers. The event is treated as a high-priority security incident because multiple affected endpoints may indicate a common entry point, lateral movement, credential compromise, data theft, destructive activity, or ransomware preparation. The primary objectives are to protect people and business operations, preserve evidence, stop spread, remove the attacker foothold, restore trusted services, and prevent recurrence.

The response is organized around four operational phases: detection and analysis, containment, eradication, and recovery. The actions follow a risk-based incident-response approach: collect evidence before it disappears, isolate affected systems without destroying volatile data, reset compromised access, rebuild systems from trusted sources, and restore only after validation. NIST SP 800-61 Revision 3 emphasizes integrating incident response with broader cybersecurity risk management; this report applies that principle to the immediate incident.

Report Objectives

- Confirm the scope, malware behavior, and business impact.
- Contain the infection and block attacker communication.
- Eradicate malicious code, persistence, vulnerabilities, and compromised credentials.
- Recover systems and data safely with heightened monitoring.
- Document evidence, decisions, communications, and lessons learned.

1. Incident Background

1.1 Scenario and Assumptions

Endpoint security tooling has raised alerts on 20 Windows computers across several departments. Indicators include suspicious process execution, outbound connections to unfamiliar domains, antivirus detections, and unusual login activity. The organization has an endpoint detection and response (EDR) platform, centralized identity management, a firewall, backups, and an incident-response team. The exact malware family is initially unknown, so responders must avoid assumptions such as treating it as only adware or only ransomware.

1.2 Incident Classification

Factor	Assessment	Response Implication
Affected endpoints	20 computers	Escalate to major incident; inspect adjacent systems.
Business impact	Potentially high	Protect critical services and determine outages.
Data exposure	Unknown	Investigate access, exfiltration, and credential theft.

MALWARE INFECTION INCIDENT RESPONSE REPORT

Threat type	Unconfirmed malware	Use evidence-based containment and forensic triage.
Priority	High	Activate incident commander and communications plan.

2. Assets and Business Impact

The incident may affect endpoints, user credentials, file shares, email, cloud sessions, line-of-business applications, backups, security logs, and customer or employee data. The CIA triad helps assess impact: confidentiality may be affected if data is stolen; integrity may be affected if files or settings are changed; availability may be affected if systems are encrypted, disabled, or quarantined.

Asset	Potential Effect	Priority
Endpoints	Malicious execution, persistence, disruption	High
Credentials and tokens	Account takeover and lateral movement	Very High
File shares	Encryption, deletion, or exfiltration	Very High
Email and cloud services	Phishing propagation and data access	High
Backups	Recovery failure if altered or reachable	Very High
Logs and evidence	Loss of visibility and legal evidence	High

3. Detection and Analysis

3.1 Initial Detection Actions

- Open an incident ticket, assign an incident commander, and record the first alert time, hostnames, users, detection names, and responders.
- Validate alerts with EDR telemetry, antivirus logs, Windows event logs, DNS/proxy/firewall logs, identity logs, and user reports.
- Identify indicators of compromise (IOCs): file hashes, filenames, processes, services, registry keys, scheduled tasks, domains, IP addresses, email subjects, and credential events.
- Determine whether affected machines share a user, software, network segment, removable media, phishing email, remote-access tool, or privileged account.
- Prioritize evidence collection from a small representative sample before broad remediation: memory capture where feasible, running processes, network connections, autoruns, recent files, and relevant logs.

3.2 Scope and Severity Questions

Question	Evidence Source	Decision
Is malware still executing?	EDR process tree, memory, event logs	Isolate immediately if active.
Is command-and-control present?	DNS, proxy, firewall, EDR network events	Block destinations and hunt enterprise-wide.
Are credentials compromised?	Identity logs, browser/token artifacts	Revoke sessions and reset accounts.
Did data leave the organization?	Proxy, cloud audit, DLP, firewall logs	Escalate privacy/legal assessment.
Is encryption or destructive behavior occurring?	File activity, backups, EDR telemetry	Protect shares and activate business continuity.

4. Containment Strategy

Containment should be fast but deliberate. The team should preserve sufficient evidence first, then stop spread and attacker control. Do not reconnect an affected endpoint merely to “see if it works,” and do not use shared administrator credentials from a potentially compromised workstation.

4.1 Immediate Containment - First Hour

- Use EDR network isolation for all confirmed infected computers; allow only the management channel when available. If EDR isolation is unavailable, disconnect Ethernet and disable Wi-Fi while retaining power for forensic capture.
- Block known malicious domains, IP addresses, hashes, URLs, and email senders at DNS, web proxy, firewall, EDR, and email controls.
- Temporarily restrict affected user accounts, revoke active cloud sessions, and rotate passwords or reset tokens when credential theft is suspected.
- Protect shared drives and critical servers: restrict write access, segment vulnerable network areas, and verify backup repositories are isolated from production credentials.
- Suspend risky remote-access paths or vulnerable services if evidence shows they are the entry point; use change control and record business impact.

4.2 Enterprise Containment - First Day

- Run EDR and IOC searches across all endpoints, servers, and identity logs; isolate any additional confirmed or strongly suspected hosts.
- Apply network segmentation rules that limit east-west traffic and block unnecessary administrative protocols between user subnets.
- Quarantine suspected phishing messages, block malicious attachments/URLs, and notify employees not to interact with related content.
- Create a clean administrative workstation and use separate incident-response accounts with MFA for recovery activities.
- Maintain a host-status ledger: infected, suspected, isolated, evidence captured, rebuilt, validated, and returned to service.

5. Eradication Strategy

Eradication removes both the visible malware and the conditions that enabled it. Deleting one executable is not sufficient: attackers may leave scheduled tasks, services, registry run keys, web shells, stolen credentials, remote tools, altered group policies, or secondary payloads.

Eradication Action	Owner	Validation
Identify malware family and behavior	Forensics / threat intel	Confirm IOCs and persistence methods.
Reimage affected endpoints	Desktop engineering	Use approved gold image and current patches.
Remove persistence and unauthorized tools	IR / endpoint team	EDR scan and manual persistence review.
Patch exploited weakness	Vulnerability management	Scan shows remediation installed.
Reset affected credentials	Identity team	Sessions revoked; MFA and privileged accounts reviewed.
Remove malicious email/cloud artifacts	Messaging / cloud team	Search confirms tenant-wide removal.

5.1 Preferred Remediation Method

For confirmed compromised employee computers, the preferred method is a full wipe and rebuild from a trusted, patched image. This is more reliable than attempting to disinfect every artifact. Preserve required evidence before rebuilding, maintain chain-of-custody notes, and recover user data only after malware scanning. If a critical server cannot be rebuilt immediately, use a documented exception, isolate it, obtain specialist approval, and plan a controlled rebuild.

6. Recovery Strategy

Recovery returns systems to normal operation only after the team has confidence that containment and eradication are effective. Restore in phases, beginning with a small pilot group and business-critical services. Recovery must be coordinated with business owners, IT operations, legal/privacy staff, and leadership.

6.1 Recovery Checklist

- Verify backups are clean and immutable or otherwise protected; test restoration in an isolated environment before production use.
- Rebuild each endpoint from a trusted image, apply operating-system and application patches, install EDR, enable encryption, and apply baseline configuration.
- Restore approved user data from scanned backups; do not restore unknown executables, scripts, browser profiles, or unverified archives.
- Reset passwords for affected users and review privileged accounts, service accounts, API keys, certificates, and active sessions.
- Return hosts to the network in controlled batches; monitor endpoint, DNS, proxy, authentication, and file-access events for recurrence.
- Obtain user and business-owner confirmation that the restored system is functional, then update the host-status ledger.

6.2 Recovery Acceptance Criteria

Criterion	Evidence
No active IOCs	Enterprise EDR and log searches are clean.
Endpoint baseline restored	Patched OS, EDR healthy, encryption enabled, least privilege applied.
Identity risk addressed	Passwords/tokens reset and suspicious sessions removed.
Business data verified	Restored files pass integrity and business-owner checks.
Monitoring heightened	Alert rules and daily review active for defined period.
Leadership approval	Incident commander records recovery decision.

7. Communication and Coordination

The incident commander should run scheduled status updates and maintain one authoritative incident record. Technical details should be shared on a need-to-know basis. Employees should receive clear instructions: do not reconnect isolated computers, do not delete suspicious files, report unusual prompts, and use alternate processes if systems are unavailable. Legal, privacy, human resources, insurers, customers, regulators, or law enforcement should be engaged based on contractual obligations, data exposure, and applicable law.

8. Lessons Learned and Improvement Plan

- Conduct a post-incident review after services stabilize; identify root cause, time to detect, time to contain, and control failures.
- Convert observed IOCs and tactics into permanent detection rules, threat-hunting queries, and block lists.
- Close the entry path through patching, MFA, email hardening, segmentation, application allowlisting, least privilege, and secure remote access.
- Test backup restoration, tabletop exercises, and EDR isolation workflows regularly.
- Provide targeted awareness training if phishing, unsafe downloads, password reuse, or policy violations contributed to the incident.

9. Ethical and Legal Considerations

Responders should collect only information necessary for investigation, protect employee privacy, preserve evidence accurately, and avoid accessing unrelated personal content. If personal data or regulated data may have been accessed, the organization should involve legal and privacy teams to evaluate notification duties. Communications must be truthful, approved, and timely; staff should not speculate about attribution or breach impact before evidence supports those conclusions.

10. Conclusion and Recommendations

A malware infection on 20 computers must be treated as a coordinated enterprise incident, not as 20 independent antivirus events. Effective response requires rapid evidence-led detection, isolation of affected devices, enterprise-wide hunting, elimination of persistence and credential compromise, trusted rebuilds, controlled restoration, and sustained monitoring. The organization should use this event to improve asset inventory, endpoint visibility, identity protections, segmentation, backup resilience, and incident-response practice.

Key Recommendations

- Isolate confirmed infected hosts immediately while preserving priority evidence.
- Hunt for the same IOCs across endpoints, servers, email, cloud, and identity systems.
- Rebuild compromised endpoints from trusted images instead of relying only on file deletion.
- Reset potentially compromised credentials and revoke active sessions.
- Validate backups before restoration and recover in controlled batches.
- Document lessons learned and measure improvements through exercises.

11. References

National Institute of Standards and Technology (NIST). SP 800-61 Revision 3, Incident Response Recommendations and Considerations for Cybersecurity Risk Management: A CSF 2.0 Community Profile, April 2025.
<https://csrc.nist.gov/pubs/sp/800/61/r3/final>

Cybersecurity and Infrastructure Security Agency (CISA). #StopRansomware Guide, containment and eradication guidance.
<https://www.cisa.gov/stopransomware/ransomware-guide>

Appendix A - Incident Command Structure

A coordinated incident requires clear accountability and a single source of truth. The incident commander prioritizes safety, business impact and evidence preservation while technical teams execute assigned work.

- Incident commander: approves priorities and escalation.
- Forensics lead: preserves and analyzes evidence.
- Endpoint lead: isolates, rebuilds and validates hosts.
- Identity lead: resets accounts, tokens and privileged access.
- Communications lead: provides approved internal and external updates.

Appendix B - Evidence Preservation Checklist

Evidence should be collected lawfully, logged with timestamps and stored in protected locations. Collection must not unnecessarily alter the affected endpoint or overwrite volatile data.

- Record hostname, user, IP address and detection time.
- Capture EDR alert details and process trees.
- Preserve volatile data from representative systems when feasible.
- Collect relevant Windows, DNS, proxy, firewall and identity logs.
- Hash collected files and maintain chain-of-custody notes.

Appendix C - Host Status Ledger

The security team should track every potentially affected computer from initial alert to approved return to service. The ledger prevents duplicate work and supports management reporting.

- Asset identifier and user.
- Detection source and time.
- Isolation state and evidence status.
- IOC matches and suspected infection vector.
- Rebuild, validation and return-to-service approval.

Appendix D - Enterprise Hunting Plan

Hunting looks beyond the initial 20 devices for related attacker activity. Searches should be repeated after new indicators are discovered and should include endpoints, identity systems, network telemetry and cloud logs.

- Search known hashes, paths, domains and IP addresses.
- Search for parent/child process patterns and persistence techniques.
- Review anomalous authentication and privilege changes.
- Identify lateral movement through remote-management protocols.
- Document negative as well as positive search results.

Appendix E - Credential Recovery Plan

Credential recovery is required when malware may have captured passwords, tokens, browser cookies or privileged sessions. Recovery must be sequenced so that attackers cannot immediately reuse access.

- Disable or reset high-risk accounts first.
- Revoke active cloud sessions and refresh tokens.
- Rotate privileged, service and API credentials.
- Verify MFA enrollment and remove unauthorized methods.
- Monitor for unusual sign-ins after reset.

Appendix F - Backup and Restore Validation

Backups support recovery only when their integrity and separation from compromised systems are verified. Restore testing should happen in an isolated environment before production cutover.

- Identify last known good recovery points.
- Verify backup access is separated from normal administrator accounts.
- Scan restored files before reuse.
- Test application function and data integrity.
- Record restoration source, time and approver.

Appendix G - Recovery Communications

Recovery communication keeps leadership and users informed without exposing sensitive technical detail. Messages should state what is known, what actions users must take, and when the next update will arrive.

- Use approved channels and a consistent cadence.
- Avoid speculative attribution or breach claims.
- Tell users how to report new symptoms.
- Coordinate customer, regulator and insurer notices through legal counsel.
- Record all material decisions and statements.

Appendix H - Post-Incident Metrics

Metrics help determine whether the response reduced impact and identify improvements for future incidents. Results should be reviewed by technical teams and leadership after stabilization.

- Time to detect and time to contain.
- Number of endpoints affected and rebuilt.
- Time to restore essential services.
- Percentage of hosts with current EDR and patches.
- Completion of corrective actions and tabletop exercises.